

College of Computer and Information Science

Alrajhi Bank

Cys 403

Prepared by:

Dana Alassaf - 222410429

Wadha Alarifi - 222410758

Noura Alalshaikh-222410395

Nora Alomier-222410172

Supervised By

Dr. Samah Abdullah Y Almutlaq

Table of Contents

Executive summary.....	3
Introduction.....	3
Security Environment.....	4
Past and Recent Security Incidents.....	6
Major Security Issues.....	8
1. Phishing and Social Engineering Attacks.....	8
2. Viruses and Bogus Banking Software.....	8
3. Account Takeover and Credential Theft Risk.....	8
4. Privacy of Data and Exposure to sensitive information.....	8
5. Fraud and Transaction Manipulation Threats.....	9
6. Expanding Attack Surface from Digital Banking Growth.....	9
Threats, Vulnerabilities, and Affected Assets.....	9
Risk Management Plan.....	10
Risk Register.....	11
Risk Matrix table.....	12
Evaluation of Authentication and Data Confidentiality Techniques.....	12
Multi-Factor Authentication (MFA) and OTP-Based Verification:.....	13
Role-Based Access Control (RBAC).....	13
Encryption/ Tokenization of Data.....	14
Analysis of Security Policies and Customer Guidelines.....	14
1. Privacy Policy and Data Protection.....	14
2. Fraud Awareness and Customer Security Guidelines.....	15
3. Principles of Consumer Protection and Responsibility of Services.....	16
Proposed Enhanced Security Approach.....	17
How the Proposed Approach Improves the CIA Triad.....	18
Confidentiality.....	18
Integrity.....	19
Availability.....	19
Security Controls Mapped to CIA Triad.....	19
Conclusion.....	20
References.....	22

Executive summary

This report is a security analysis and risk assessment of Al Rajhi Bank in the framework of its online banking business in Saudi Arabia. Al Rajhi Bank, being one of the largest banking institutions in the Kingdom, heavily depends on online banking, mobile banking and interconnected digital services in order to deliver services to millions of customers and a variety of financial transactions. Due to this, cybersecurity is a major aspect in safeguarding customer accounts, personal and financial information, accuracy of transactions, and continuity of the services. In the report, the authors look at the current security environment in the bank through its technical controls, governance structure, privacy practices, fraud-awareness practices and regulatory alignment. It also determines the significant security challenges to the bank such as phishing, malware, stealing credentials, the risk of data confidentiality, the growth of digital attack surfaces, and service availability. A systematic risk management program is then formulated by categorizing the risks in the six components of the information systems and suggesting appropriate controls in each of the areas. In addition, the report evaluates important authentication and data confidentiality techniques such as multi-factor authentication, role-based access control, and encryption. The paper also examines the security policies and customer guidelines of the bank with particular reference given to the privacy protection, fraud awareness policies, and the security responsibilities of customers. Plans are made based on the findings to improve the security methodology to boost fraud monitoring, authentication, application security, access control, customer awareness and operational resilience. It is concluded in the report that despite the excellent commitment of Al Rajhi Bank to cybersecurity and compliance, the aspect of continuous improvement should not be ignored since the digital banking threat landscape keeps changing. Lastly, the paper gives an explanation of how the suggested enhancements will improve the confidentiality, integrity and availability of the bank systems and services, which will in turn promote greater trust, resilience and performance of security in the long term.

Introduction

Al Rajhi Bank is a leading and largest banking institution in Kingdom of Saudi Arabia and it is a key business in terms of delivering personal and business financial services by means of branches, ATM, online banking and mobile banking services. The bank was established in 1957 and has expanded wide digital presence serving millions of customers and providing over 200 services

using its application and electronic platforms. Due to all this dependence on digital systems, Al Rajhi Bank is in a very sensitive environment, where cybersecurity is a necessity in safeguarding customer accounts, financial transactions, confidential data, and service continuity. Being one of the top online banking providers overseen by the Saudi Central Bank (SAMA), the bank should have a high level of technical, procedural, and organizational controls to protect against phishing, unauthorized access, fraud, data leakage, malware, and service disruption among other threats. The growth of the adoption of digital banking services has increased customer convenience, yet has also widened the attack surface of the bank and made it vulnerable to new cyber threats. Thus, it is significant to examine the present security status of Al Rajhi Bank to know the key weaknesses, potential threats, and the effectiveness of controls implemented in the bank. The present report concentrates on the digital banking environment of the bank and uses the principles of security risk management to determine the key security concerns, categorize the risks in the six information system elements, and suggest mitigation strategies. The report also analyzes the security policies and customer guidelines at the bank and offers a more effective security strategy to improve security. Lastly, the paper discusses how the suggested enhancements would be useful in ensuring the confidentiality, integrity, and availability of the systems and services of Al Rajhi bank.

Security Environment

The security environment of Al Rajhi Bank is currently comprised of both the technical and organizational measures aimed at the protection of the customer data, financial transactions, digital banking services, and internal operations. Being one of the largest banks in Saudi Arabia with 19 million+ customers and 200+ services in Al Rajhi Bank app, the bank exists in a very sensitive digital space where cybersecurity is the key to ensuring trust, compliance with the regulations, and operational stability.

Examples of its technical measures include:

Data Encryption: According to the privacy policy of Al Rajhi Bank, the bank encrypts its data in transit along with those that are at rest. This is a significant protection as the bank deals with very sensitive personal and financial data with its mobile application and digital channels. The encryption minimizes the chances of unauthorized disclosure in case information is intercepted or accessed unlawfully.

Access Controls: The bank describes that it has firm access controls and role-based access control (RBAC) to control who can access or modify personal data depending on job roles and responsibilities. This will assist in curbing insider abuse, limit the unneeded access to sensitive records and also aid the confidentiality and integrity of customer data.

Monitoring and Detection: Al Rajhi Bank reports that its 24/7 cybersecurity operations center is monitoring and responding to cyber threats and attacks. It also implements ongoing cybersecurity testing of its systems, applications, and networks. These issues show that the surroundings of the bank have real time monitoring and continuous detection services to help it detect suspicious activity before it can cause significant harm.

Preventive, Detective, and Incident Response Controls: According to the bank, it implements extensive series of dynamic defenses, such as preventive, detective, and incident response measures. This demonstrates that its security environment is not restricted to preventing attacks alone, but also has the capability of observing incidents and taking action when the threats become a reality.

Fraud and Authentication Awareness Controls: On its fraud awareness page, the bank advises its customers against revealing their bank password or SMS OTP and it states that the bank would never demand such details over the phone, SMS, or email. It also brings out the identity factors like something you know, something you have and something you are and indicates that the environment of the bank places more emphasis on the awareness of stronger authentication as one of the elements of fraud prevention.

Digital Banking Channels Protection: Al Rajhi specifically informs customers about fraud targeting Al Mubasher users, such as harmful viruses and malicious authentication programs, and asks them to be suspicious of suspicious login forms or pop-up requests to provide their mobile number, card number, or ATM PIN. This demonstrates that the existing security climate of the bank is particularly concerned with safeguarding online banking clients against phishing, malware, and credential theft.

Its organizational measures involve:

- Cybersecurity Governance and Oversight
- Policies and Procedures

- Employee Training and Security Awareness
- Customer Awareness and Fraud Education
- Audit, Compliance, and Regulatory Alignment
- Incident Handling and Breach Procedures

Past and Recent Security Incidents

There is no confirmed large cybersecurity breach of Al Rajhi Bank itself in the recent years 2023/2024 reporting periods publicly available. Indeed, the disclosures made by the bank indicate that it has not registered any cybersecurity breaches or operational effects in those times. Nevertheless, digital banking users have repeatedly fallen prey to actual cyber-attacks and fraud schemes, particularly phishing, malware, counterfeit apps, and credential theft, as well as Al Rajhi bank and its customer base.

- **Al Rajhi customers cyber-attack on the Internet in 2004.**

In July 2004, Arab News announced that internet banking usernames and passwords of customers of a number of Saudi banks, including Al-Rajhi Banking and Investment Corp., were targeted in an online attack. The malicious pop-up ads were employed by the attack to install key stroke logging malware in the computers of the victims. The significance of this incident is that it demonstrates that Al Rajhi already had an online banking environment being targeted in the early stages of digital banking adoption, particularly by malware on the customer side over direct bank internal system compromise.

- **2014 malware and token-swine -scams of Saudi bank consumers.**

In February 2014 Arab News announced that swindlers were targeting Saudi bank customers with a malware and fake software requests to access their online bank accounts. In the report, it was particularly pointed out that the Al-Rajhi Bank had previously issued similar warnings. This is consistent with current advice on fraud-awareness given by Al Rajhi itself, which cautions the customers that should they see such fields as token or any other similar prompt displayed in the Al Mubasher login screen, it is possible that the computer has been compromised. Such an incident demonstrates a recurrent trend of attackers trying to dupe customers into providing banking information or placing malicious software.

- **In 2014, Android botnet posing as Al Rajhi mobile security apps.**

In April 2014, cybersecurity reporter Brian Krebs wrote about the San droid Android botnet, which loaded fraudulent banking applications as masqueraded mobile authentication or security modules to a number of Middle Eastern banks, including Al Rajhi Bank. The malware had apparently infected thousands of phones and stolen tens of thousands of SMS messages, which, according to the report, could enable criminals to steal one-time codes facilitated by banking authentication. The incident is very topical as it illustrates a practical danger to the mobile banking users by the use of a fake application, mobile malware, and interception of OTP.

- **2022 phishing-kit attack pretending to be Al Rajhi bank online banking.**

In April 2022, cybersecurity company Resecured announced the results of a phishing campaign in Saudi Arabia that contained several phishing kits that attempted to steal online banking credentials of customers of major Saudi banks. The report particularly indicated that one of the phishing pages belonged to the AL Rajhi Bank and explained how the kits had been set up to steal customer credentials and card information. It further said that the larger operation contained records of stolen credentials and indicates of unauthorized transfers in the larger operation. This is among the latest and most powerful indications that Al Rajhi clients continued to be the active targets of organized phishing and credential-harvesting schemes.

- **On-going phishing and fraud against the environment in 2024.**

Though the bank did not publicly report any major breach in 2024, the bank itself reported that phishing and fraud continued to be active enough to warrant dedicated phishing awareness campaigns during the year, such as a phishing awareness campaign during Eid al-Adha, newsletters about phishing scams during National Day, and fraud-awareness events with customers. This indicates that the current threat condition surrounding Al Rajhi remains strongly influenced by the attempted social engineering and internet fraud as of now, even in the instance where a significant successful attack has not been announced publicly.

These occurrences indicate that the primary actual threats associated with Al Rajhi Bank have been directed towards the customer-facing digital platforms instead of publicly verified internal system breach. The trend is evident: attackers continuously attack Al Rajhi users via phishing, malware, fake applications, stealing credentials, and OTP interception. Thus, the risk exposure of the bank is

closely connected with the security in online banking, the awareness of the customers, the detection of fraud, and high levels of authentication.

Major Security Issues

1. Phishing and Social Engineering Attacks

Phishing and social engineering against its customers in the form of fake messages, malicious links, spoofed login pages, and fraudulent requests of passwords or OTP codes is one of the largest security threats to Al Rajhi Bank. This problem is also obviously topical as the bank explicitly advises their customers against sharing passwords or SMS verification code and actively conducts phishing-awareness campaigns, yet third-party reporting has reported phishing kits that replicate the online banking pages of Al Rajhi bank.

2. Viruses and Bogus Banking Software.

Malware on devices of customers is another significant threat, particularly bogus authentication apps or malicious mobile apps that attempt to steal credentials and intercept one-time passwords. This risk is extremely applicable to Al Rajhi since the public reporting and the bank itself fraud management mention hacked devices, counterfeit prompts, and other fraudulent apps that resemble applications targeting digital banking customers, which can be used to access unauthorized data even without a direct attack on the internal systems of the bank.

3. Account Takeover and Credential Theft Risk.

The digital channels of Al Rajhi Bank are also under constant threat of hijacking customer accounts by stealing their usernames, passwords, and verification factors. This is a critical problem since online banking depends greatly on secure authentication, and in Saudi Arabia, campaigns have been reported where fraudsters have been actively trying to extract customer details of leading banks, such as Al Rajhi, to commit fraud and illegal transfers.

4. Privacy of Data and Exposure to sensitive information.

Being a large digital bank with millions of clients, Al Rajhi has an extraordinarily sensitive level of personal and financial data, thus any vulnerability in data management, data sharing, data storage, or access control may pose significant privacy and compliance threats. In its own publications, the

bank mentions data governance, data classification, personal data protection, encryption, and controlled access as a key element of security concerns in its operating environment, which serves as an indicator that the safety of customer information is a primary security concern in its environment.

5. Fraud and Transaction Manipulation Threats.

Fraud is one of the most significant security concerns since attackers do not necessarily need to hack into the infrastructure of the bank; they can use customers, the behavior of payments, or weak links within the digital transactions streams to create a loss of money. Al Rajhi annual reporting focuses on fraud prevention, compliance with the Counter Fraud Framework by SAMA and reliance on strong systems to identify and deter frauds, which shows that the risk of fraud is high enough to be addressed by special governance and control.

6. Expanding Attack Surface from Digital Banking Growth

A larger security concern would be the increasing attack surface as a result of the Al Rajhi fast digitalization, such as the app-based services, APIs, digital customer experiences, and 24/7 banking services. The bank itself reports of a big digital ecosystem, continuous modernization of the platform, and 24/7 cybersecurity, which indicates that the greater the digital capabilities, the more potential entry points, dependencies, and security exposures.

Threats, Vulnerabilities, and Affected Assets

Threat	Main Vulnerability	Affected Asset	Possible Impact	Priority
Phishing and social engineering	Customers may click fake links or share OTPs	Customer accounts, login credentials, OTPs	Account takeover, unauthorized transactions, financial loss	Critical
Fake banking applications	Users may install malicious apps pretending to be banking tools	Mobile banking users, OTP messages, device data	Credential theft, SMS interception, malware infection	High
Credential theft	Weak password behavior, reused passwords, phishing pages	Online banking accounts	Unauthorized login and fraudulent transfers	Critical
Malware on customer	Compromised phones or computers	Mobile app sessions,	Session hijacking, data theft,	High

devices		browser sessions, OTPs	transaction manipulation	
Data exposure	Weak access control, third-party sharing, poor data governance	Customer personal and financial data	Privacy violations, regulatory penalties, reputation damage	Critical
Insider misuse	Excessive employee privileges or poor monitoring	Internal systems, customer records	Unauthorized access, data manipulation, privacy breach	High
API exploitation	Weak API authentication, insecure integration, poor testing	Digital banking APIs and services	Data leakage, service abuse, transaction fraud	High
DDoS or service disruption	Heavy reliance on digital banking channels	Mobile banking, online banking, payment services	Service unavailability and customer dissatisfaction	High
Transaction fraud	Abnormal transfers, mule accounts, stolen credentials	Customer funds and transaction systems	Direct financial loss and customer complaints	Critical
Third-party risk	Vendors or partners may have weak security controls	Shared systems, outsourced services, customer data	Indirect breach, compliance issue, operational disruption	Medium–High

Risk Management Plan

IS Component	Identified Risk	Likelihood	Impact	Inherent Risk	Risk Treatment	Key Controls	Residual Risk	Risk Decision
Hardware	Infrastructure disruption affecting digital banking services	Medium	High	High	Mitigate	Redundancy, failover, DR site, backup power, monitoring	Medium	Accept with continuous resilience testing and monitoring
Software	Vulnerabilities in apps, APIs, middleware, mobile banking	High	High	Critical	Mitigate	Secure SDLC, patching, penetration testing, code review, API security	Medium–High	Reduce further through continuous testing and management oversight
Network	Intrusion, DDoS, malicious traffic, communication compromise	High	High	Critical	Mitigate	Firewalls, IDS/IPS, DDoS protection, segmentation, encrypted channels, SOC	Medium	Accept with ongoing monitoring and periodic network review
Data	Exposure or misuse of customer personal/financial data	High	High	Critical	Mitigate	Encryption, RBAC, DLP, classification, audits, logging	Medium	Accept only with strict privacy governance and compliance review
People	Phishing, social	High	High	Critical	Mitigate	Awareness training,	High	Not fully

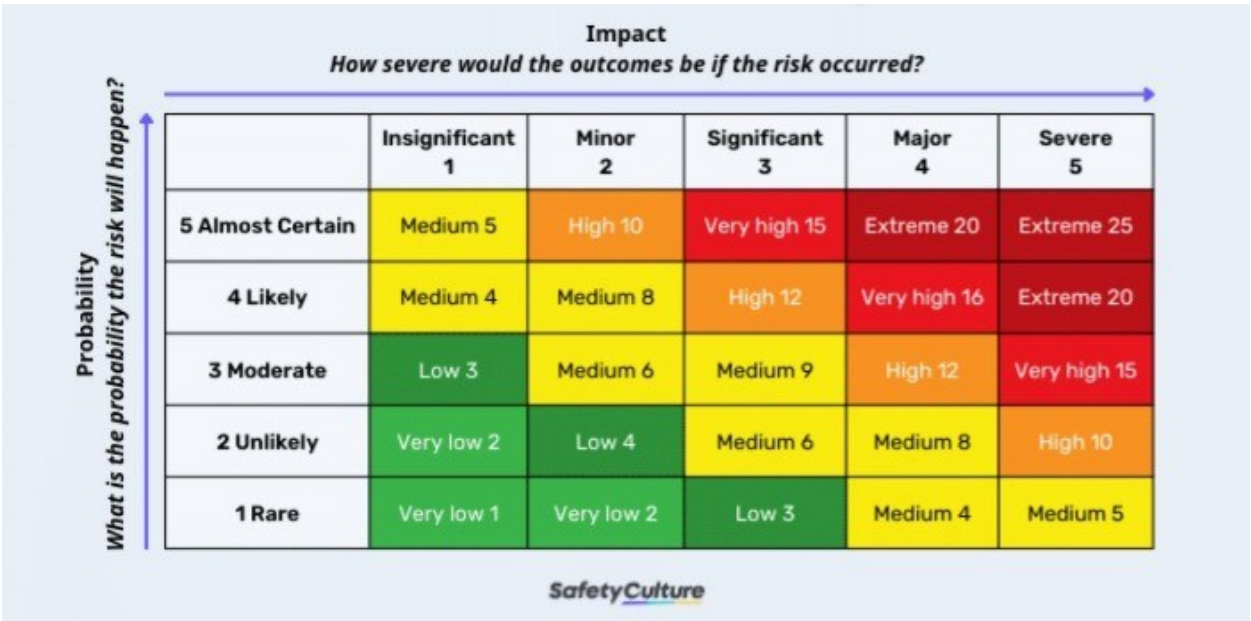
	engineering, insider misuse, human error					phishing simulation, MFA, PAM, fraud reporting		acceptable; requires continuous awareness and fraud detection
Procedures	Weak response, poor third-party oversight, delayed escalation	Medium	High	High	Mitigate	Incident response updates, access review, third-party controls, testing	Medium	Accept with regular review, drills, and audit follow-up

Risk Register

Risk ID	Risk Description	IS Component	Likelihood	Impact	Risk Level	Existing Controls	Recommended Treatment	Risk Owner
R1	Phishing attacks targeting customers through fake messages and login pages	People / Software	High	High	Critical	Fraud awareness, OTP warnings, customer guidelines	Add phishing-resistant MFA and in-app warnings	Fraud Risk Manager
R2	Fake mobile banking apps stealing credentials and OTPs	Software / People	High	High	Critical	Fraud awareness, app security controls	Improve app-store monitoring, anti-tampering, customer alerts	Application Security Lead
R3	Unauthorized employee access to customer data	Data / People	Medium	High	High	RBAC, access control, audit logs	Enforce least privilege and quarterly access reviews	IAM Manager
R4	Sensitive customer data exposure	Data	High	High	Critical	Encryption, privacy policy, access controls	Strengthen DLP, classification, retention, third-party controls	Data Protection Officer
R5	Vulnerabilities in mobile banking or APIs	Software	High	High	Critical	Security testing, monitoring, secure development	Add continuous penetration testing and API security review	Application Security Lead
R6	Fraudulent transactions using stolen credentials	Data / Procedures	High	High	Critical	OTP, fraud monitoring, customer alerts	Use behavioral analytics and real-time transaction scoring	Fraud Risk Manager
R7	DDoS or infrastructure	Network / Hardware	Medium	High	High	Monitoring, redundancy,	Strengthen DDoS	Network Security

	disruption					incident response	protection and recovery drills	Manager
R8	Weak incident escalation or delayed response	Procedures	Medium	High	High	SOC, incident response procedures	Conduct cyberattack simulations and response testing	SOC Manager
R9	Third-party vendor security weakness	Procedures / Data	Medium	High	High	Vendor agreements and compliance controls	Add vendor risk scoring and periodic audits	Third-Party Risk Manager
R10	Human error by employees handling sensitive information	People	High	Medium	High	Employee training and policies	Role-based awareness training and phishing simulations	Security Awareness Officer

Risk Matrix table



Evaluation of Authentication and Data Confidentiality Techniques

To safeguard customer accounts, transactions, and personal information in its digital banking, Al Rajhi Bank employs a blend of authentication and data confidentiality measures to secure online banking services. According to the official privacy and fraud-awareness statements of the bank, along with the banking security and counter-fraud regulations by the SAMA, multi-factor

authentication with OTP and device/user verification, role-based access control, and data encryption/tokenization are identified as the three most applicable techniques. The significance of these techniques is that security in online banking cannot be achieved purely by preventing unauthorized access, but in addition to this, the attacker should not be allowed to do anything even when one of these controls has been overcome.

Multi-Factor Authentication (MFA) and OTP-Based Verification:

Multi-factor authentication, particularly, one-time passwords and step-up authentication of sensitive operations, is one of the most significant authentication methods used in the banking landscape. Al Rajhi bank has made it clear severally that customers should not share SMS OTPs, indicating that OTPs are an actual element to its authentication and transaction-verification culture. The rulebook of SAMA also obliges member organizations to uphold an authentication standard on digital channels and send OTPs on verifying payments, particularly when it comes to transactions or beneficiaries. The key advantage of this method is that it provides an extra layer to the password, minimizing the likelihood of stolen password being used to gain access to a particular account or abuse it. But its weakness is that OTP-based controls continue to be vulnerable to phishing, SIM-based fraud, malware or interception of the SMS in case the device of the customer is compromised. Thus, it is a successful technique, albeit more powerful in conjunction with the device binding, fraud analytics, and customer awareness.

Role-Based Access Control (RBAC)

A second important technique is role-based access control, which Al Rajhi explicitly mentions in its privacy policy. According to the bank, it applies stringent access measures and access controls that allow employees to only access or manipulate personal information based on job responsibilities. It is a powerful authentication and authorization support option since it minimizes the insider risk, limits the abuse of privileges and promotes the principle of least privilege. RBAC is particularly useful in a banking context, where not all members of the staff are to be given access to customer profiles, transaction records, fraud systems and administrative tools. Its greatest strength is that even a valid user account will give a user no access to everything. Its weakness is that RBAC can only be effective so long as the roles are periodically revisited, extraneous permissions are eliminated as soon as possible, and the privileged activity is monitored. The

control may be weaker if the role definitions are not updated or are too broad. In general, RBAC is a very powerful organizational and technical method of ensuring confidentiality and integrity of banking systems.

Encryption/ Tokenization of Data

The third important method is encryption, along with some elements of payment, tokenization. According to Al Rajhi, it employs encryption to secure personal data during transit and at rest that is the essence of confidentiality that is the main protection of digital banking systems. Moreover, its Google Pay and Samsung Pay data singles out such security measures as encryption, tokenization, fingerprint recognition, facial recognition, and PIN-protected security. The beauty of encryption is that sensitive customer and transaction data is not disclosed to unauthorized persons should traffic be intercepted or stored data be exposed. The tokenization also enhances confidentiality because, instead of the actual card information, secure digital tokens are used to process payments, minimizing the display of actual payment information. The key weakness is that encryption alone will not remove all the risk since endpoints that are compromised, stolen credentials, or poor internal key-management practices can still cause exposure. Nonetheless, encryption and tokenization are still one of the most efficient confidentiality measures in the banking of today and are vital in safeguarding customer trust and compliance requirements.

Analysis of Security Policies and Customer Guidelines

1. Privacy Policy and Data Protection

The privacy policy of Al Rajhi Bank demonstrates that the bank has a systematic attitude to the personal data protection and compliance with the regulations. According to the policy, the bank handles the customer data in accordance with the Saudi Personal Data Protection Law (PDPL) and other requirements established by the SAMA, and clarifies what kinds of personal, financial, technical, and communication data are gathered and why they are processed. The policy further indicates that they use personal data to onboard, manage their accounts, prevent fraud, manage risks, comply with the law, and protect themselves with IT, and do not share personal information with third parties except as authorized by law, operations, and regulations. Moreover, the bank indicates that third parties that handle data on its behalf are under the relevant contractual and security commitments, and outbound transfers outside Saudi Arabia should adhere to the PDPL.

and SAMA requirements. This policy is robust as it encourages transparency, legal handling, sharing that is required to be minimal, and governance of data protection. Nonetheless, since the policy permits the wide ranges of processing and sharing with third parties under the operational and regulatory grounds, it nevertheless needs the transparent awareness of customers and the robust use of internal controls to guarantee that the secrecy of data is upheld in practice.

2. Fraud Awareness and Customer Security Guidelines

Fraud prevention and user awareness are highly emphasized in the customer security guidance of Al Rajhi Bank. The bank provides clear instructions to customers on its official fraud-awareness page, making it clear that the bank would never ask them to divulge their bank password or SMS OTP, and it would never request such information via phone calls, SMS, or email. It also cautions customers to ignore any suspicious instructions in regards to ATM or online banking and specifically informs the user that in case there are any strange fields like token, or AL Rajhi certificate visible on the Al Mubasher log in screen, then the device might have been compromised. The page continues to add that the bank has been receiving lots of fraud complaints in relation to the existence of malicious viruses and fraudulent authentication applications affecting the customers. This guidance works well as it directly touches on the most prevalent threats of digital banking, such as phishing, malware, credential theft, and fake app attacks. The greatest strength is that it provides easy and explicit instructions that can be comprehended by ordinary users. Nevertheless, it remains dependent on the willingness of the customers to read, remember and act on the advice regularly, implying that awareness campaigns should be maintained at regular intervals and incorporated into digital banking platforms.

Communication and Escalation Matrix

Security Issue	Reported By	Reported To	Responsible Owner	Action Needed
Phishing message or fake link	Customer / Employee	Customer Support or IT Helpdesk	Fraud Risk Team	Block link, warn users, and investigate
Suspicious transaction	Fraud monitoring system / Customer	Fraud Team	Fraud Risk Manager	Verify transaction and contact customer
Fake banking app	Customer /	SOC Team	Application	Report fake app

	Security Team		Security Team	and alert customers
Unauthorized employee access	System logs / Manager	IT Security Team	IAM Manager	Review access and suspend if needed
Data privacy incident	Employee / Monitoring system	Data Protection Officer	Compliance Team	Investigate and protect affected data
Malware or virus alert	Employee / SOC system	SOC Team	SOC Manager	Isolate device and remove malware
Service outage or network attack	Monitoring system	IT Operations Team	Business Continuity Manager	Restore service and update management
Suspicious email received by employee	Employee	IT Helpdesk	Security Awareness Officer	Analyze email and warn staff

3. Principles of Consumer Protection and Responsibility of Services.

The customer policies of the bank are also backed by the published Consumer Financial Protection Rules and Principles, which entail fair treatment, transparency, awareness and education, fraud protection, privacy protection, handling of complaints, and secure outsourcing practices. According to these principles, a financial institution is required to safeguard the customers against abuse and fraud by providing efficient technical and control measures, creating mechanisms to safeguard privacy of personal, credit, insurance, and financial information and offer secure medium of transactions. They also demand that institutions implement a variety of identity-authentication procedures to electronic services, provide customers with reasoning of the OTP messages, and uphold service continuity, and provide compensation to consumers who suffer direct loss as a direct result of ineffective security or hacked channels where necessary. This renders the guidelines very pertinent to the online banking security as they associate security with the rights of the customers, secure service provision as well as accountability in operations. On the whole, these regulations enhance the policy environment within the bank by demonstrating that the safety of customers is not just a legal obligation, but also a central element of safe banking practices.

Proposed Enhanced Security Approach

1. Strengthen Phishing-Resistant Authentication

Al Rajhi Bank needs to improve its authentication procedures by increasing phishing-resistant multi-factor authentication particularly on high-risk logins, addition of beneficiaries, and sensitive transactions. This would mitigate the threat of stolen credentials, OTP abuse, and account takeover, which is currently one of the significant threats in digital banking.

2. Introduce Adaptive Risk-Based Access Controls

The bank must implement adaptive authentication that measures the reputation of the device used, location, behavior, and context of the transactions and then allow access or authorize actions. That would simplify fraudulent logins and suspicious transaction attempts, without overwhelming the normal customer activity to an unreasonable degree.

3. Increase Continuous Fraud Monitoring

More vigorous real-time fraud detection model needs to be adopted among online banking, mobile banking, cards, and transfer channels. Transactional analysis, behavioral analytics, and priority of alerts will help the bank track suspicious trends earlier and act before financial damages are incurred.

4. Harden Cellphone and Web-based Banking Systems

Given that the customers are targeted by means of fake applications, malware, and phishing pages, the bank must enhance secure applications design, review of the code, session protection, and anti-tampering measures. Frequent penetration auditing and safe development culture would minimize vulnerabilities that can be exploited in digital banking systems.

5. Enhance Customer Security Awareness Programs

The bank must maintain and increase awareness initiatives that illustrate the concept of phishing, OTP theft, fraudulent applications, malware, and secure online banking practices. Such campaigns are expected to be displayed not only on awareness pages, but directly within the app, where users are making security-related decisions, such as on the login screens and on transaction flows.

6. Enhance Employee Cybersecurity Education

Role-based cybersecurity training should be provided to employees more often on fraud indicators, social engineering, insider risk, handling of customer data in a secure manner, and escalation

procedures. Human error is a very serious risk in banking and hence it is necessary to have staff awareness which should be done constantly to effectively control the risk.

7. Increase Privileged Access and Internal Surveillance

The bank ought to also increase the enforcement of least-privilege and reviewing of privileged accounts and audit logs of internal systems and sensitive access. This would assist in curbing the risk of insider misuse and enhance accountability in the various departments dealing with financial and personal information.

8. Enhance Data Protection and Privacy Governance

Al Rajhi Bank must ensure better data classification, encryption, retention control and third-party data-sharing controls throughout its digital ecosystem. Due to the sensitivity of banking information, privacy governance needs to be constantly examined in order to meet the requirements of PDPL, SAMA, and internal security requirements.

9. Enhance Third-Party and API Security Management

As the bank develops a digital platform, APIs and interrelated services, it must use a more rigorous third-party risk assessment, vendor security review, and API security testing. This would minimize exposure generated by the external dependencies and by the expansion of the digital transformation environment in the bank.

10. Enhance Response to Incidents and Operational Resilience

The bank ought to conduct regular incident response, crisis management, and business continuity testing with realistic cyberattack simulation and recovery exercises. This would enhance preparedness to fraud surges, service failures, malware attacks or digital bank outages and aid in sustaining consumer confidence and service presence.

How the Proposed Approach Improves the CIA Triad

Confidentiality

The suggested solution enhances confidentiality by reinforcing the protection of customer accounts, personal information and financial records due to phishing-resistant authentication, adaptive access controls, improved role-based access control and escalated encryption practices.

Such controls minimize the risk of sensitive banking information falling into the wrong hands of unauthorized users, insiders or fraudsters due to stolen credentials, malware, or lax internal controls. Moreover, enhanced privacy controls and enhanced third-party controls assist in providing a better process to handle, share, and store confidential information in a more secure and controlled way.

Integrity

The suggested solution enhances integrity by assisting in maintaining accuracy, authorization, and protection of banking transactions, account information, and system records against tampering. Secure application development, transaction monitoring, audit logs, reviews of privileged-access, and fraud detection controls make it more difficult to allow attackers or unauthorized insiders to modify information or commit fraud without being detected. Integrity is also supported by risk-based verification of high-risk transactions and ensures that any changes and transfers are real before they can be finalized.

Availability

The suggested solution enhances the availability process by making the bank more capable to ensure dependable online banking services despite the presence of cyber threats, operational malfunctions, or fraud-associated disturbances. Increased incident response, ongoing monitoring, business continuity planning, resilience testing, and secure infrastructure controls can be used to minimize downtime and ensure that when attacks or outages are experienced, the recovery is faster. This is particularly relevant in the case of Al Rajhi Bank since online banking, mobile banking and payment services should be available without fail to a very high number of customers.

Security Controls Mapped to CIA Triad

Security Control	Confidentiality	Integrity	Availability
Multi-factor authentication	Prevents unauthorized access to customer accounts	Ensures only verified users approve transactions	Reduces fraud-related account disruption
Role-based access control	Limits employee access to sensitive data	Prevents unauthorized modification of records	Reduces risk of internal misuse affecting operations

Encryption	Protects data in transit and at rest	Prevents unauthorized reading or manipulation of data	Supports secure and reliable service communication
Tokenization	Protects real card/payment data	Reduces manipulation of actual payment details	Supports secure digital payment continuity
Fraud monitoring	Protects accounts from unauthorized activity	Detects abnormal transaction changes	Prevents large-scale fraud disruption
SOC monitoring	Detects attacks and suspicious activity	Supports investigation and evidence collection	Helps maintain continuous banking services
Incident response plan	Protects exposed data during incidents	Controls damage and preserves logs	Restores services after attacks
Backup and disaster recovery	Protects stored business data	Ensures records can be restored accurately	Maintains banking service continuity
Customer awareness	Reduces OTP and password sharing	Prevents fraudulent transaction approval	Reduces customer-side service disruption
Employee training	Reduces accidental data exposure	Reduces mistakes in system handling	Improves response during security incidents

Conclusion

To sum up, Al Rajhi Bank is a highly sensitive and quickly changing online banking sector with cybersecurity as a crucial factor in securing customer trust, financial resources, and service provision. This report indicated that despite the bank boasting of good technical and organizational controls, it continues to encounter significant security issues pertaining to phishing, malware, credential theft, data confidentiality, growing digital platforms, and service availability. The analysis has also revealed that such risks impact a variety of information system elements, in particular, software, networks, data, people and procedures. On this basis, risk management should be implemented in a systematic manner to detect, evaluate and mitigate the probability and effect of cyber threats. The suggested improved security strategy with increased authentication, adapted monitoring, enhanced fraud detection, increased customer and employee awareness, restricted access controls, and enhanced resilience planning would greatly benefit the overall security stance of the bank. Such measures would also enhance the confidentiality, integrity and the availability of digital banking services. Moreover, published policies and customer guidelines of the bank demonstrate that the bank follows the principles of privacy, prevention of fraud, as well as compliance with regulations, but constant enhancement is required since the threats do not stand still. Thus, Al Rajhi Bank must further evolve a multi-layered and active approach to cybersecurity

that integrates governance, technology, awareness, and resilience. Through this, the bank will be in a better position of repelling the existing and future cyber threats in its digital ecosystem and continue to ensure secure and reliable banking services to its customers.

References

- Al Rajhi Bank. (2024). *Al Rajhi Bank AR2024 English annual report*.
https://www.alrajhibank.com.sa/ir24/services/pdf/Al_Rajhi_Bank_AR2024_English.pdf
- Al Rajhi Bank. (2024). *Corporate governance*.
https://www.alrajhibank.com.sa/ir24/corporate_governance/corporate_governance.html
- Al Rajhi Bank. (2024). *Customer fraud prevention*.
https://www.alrajhibank.com.sa/ir24/customer_engagement_and_responsible_banking/customer_fraud_prevention.html
- Al Rajhi Bank. (2024). *Data privacy and information management*.
https://www.alrajhibank.com.sa/ir24/corporate_governance/data_privacy_and_information_management.html
- Al Rajhi Bank. (2024). *Risk management*.
https://www.alrajhibank.com.sa/ir24/services/pdf/risk_management.pdf
- Al Rajhi Bank. (n.d.). *Compliance*.
<https://www.alrajhibank.com.sa/en/About-alrajhi-bank/Compliance>
- Al Rajhi Bank. (n.d.). *Fraud awareness*.
<https://www.alrajhibank.com.sa/en/About-alrajhi-bank/Fraud-Awareness>
- Al Rajhi Bank. (n.d.). *Privacy policy*.
<https://www.alrajhibank.com.sa/en/About-alrajhi-bank/privacy-policy>
- Arab News. (2004, July 3). *Customers at Saudi banks targeted in online attack*.
<https://www.arabnews.com/node/251943>
- Krebs, B. (2014, April 30). *Android botnet targets Middle East banks*. Krebs on Security.
<https://krebsonsecurity.com/2014/04/android-botnet-targets-middle-east-banks/>